

SeguimientoMedico

Reporte de avances - sesion agentica

24 de junio de 2026

Este documento resume todo lo construido desde que se activo el trabajo con agentes expertos: una auditoria multi-experto del codigo, la resolucion de los problemas criticos de seguridad, el modulo de administrador (inteligencia de negocio), nuevas funciones del producto, y la documentacion estrategica de escala y marketing.

Versiones publicadas 0.4.9 -> 0.4.22	Tests automatizados 206 (verde)	Items criticos resueltos 8
Expertos en auditoria 6 en paralelo	Hallazgos -> backlog 71 -> 40	Commits de la sesion 14+

Veredicto de la auditoria

"El nucleo cripto (AES-256-GCM, PBKDF2, HMAC) y el CRUD estan solidos. Se cerraron los agujeros que rompian flujos reales y bloqueaban cobrar: login del paciente fuerza-bruteable, falta de rate limiting, el chat pago sin validar suscripcion, y webhooks sin firma. Todo incremental y commiteable de a uno; ningun item es reescritura."

1. El metodo: auditoria con 6 expertos en paralelo

Se lanzo un workflow que puso a trabajar en paralelo a seis ingenieros expertos, cada uno con una mirada distinta sobre el codigo. Cada experto leyo los archivos reales y entrego hallazgos concretos (archivo, problema, fix y esfuerzo). Un septimo agente sintetizo los 71 hallazgos en un backlog unico, priorizado y accionable de 40 items.

Las seis miradas

- Seguridad & Privacidad - tokens, cifrado, fuerza bruta, firma de webhooks.
- UX / PWA para adultos mayores - claridad, accesibilidad, estados de error.
- Correctitud backend & gating de pago - flujos, validaciones, casos borde.
- Escalabilidad a 1k-10k - migraciones, indices, archivado de historial.
- Pagos, negocio & modulo BI - cobro, rentabilidad, instrumentacion.
- Robustez del frontend - null-safety, errores de red, sesion persistente.

Esa lista priorizada es la que guio el resto de la sesion: primero lo critico de seguridad, despues lo que faltaba para que el producto se sienta terminado, y por ultimo escala, negocio e instrumentacion.

2. Endurecimiento de seguridad (lo critico)

Firma de Twilio en /whatsapp/incoming

Era un webhook publico que modificaba la historia clinica sin verificar firma. Ahora exige X-Twilio-Signature, con un guard compartido que ademas falla-cerrado en produccion (si esta mal configurado, rechaza).

El chat pago valida la suscripcion de la familia

La charla con IA es la funcion paga. Ahora un turno real valida que la familia tenga suscripcion vigente; si no, responde con carino y sin gastar API. El saludo inicial y la prueba de 14 dias siguen gratis.

Secretos fail-closed en produccion

Fuera de entornos de desarrollo, si falta JWT_SECRET o el token de Twilio, la app deja de operar en vez de firmar con una clave publica. decode_token valida formato; el indice de telefono exige la clave de cifrado.

Rate limiting + anti fuerza-bruta del login

Limitador en memoria: login familiar 8/min, registro 5/h, login del paciente 5/min por codigo y 20/min por IP. Ademas la clave rotativa de 2 digitos ahora tiene una sola combinacion valida casi todo el tiempo (1/100 en vez de 2/100).

Bug de login por email (mayusculas)

El registro guardaba el email sin normalizar y el login comparaba en minusculas: un email con mayusculas no podia entrar. Corregido.

3. Nuevas funciones del producto

Chat real del paciente (Acompañado)

El boton 'Hablar' ahora abre una charla real con IA (OpenAI), con una personalidad calida en espanol rioplatense, personalizada con el nombre, el trato (vos/usted), el acompanante y los temas preferidos. Si falla la red, responde con carino y nunca rompe la pantalla.

Graficos de tendencia (sparklines)

En el detalle de cada persona, mini-graficos de presion, peso y animo que muestran como vienen evolucionando los ultimos dias.

Telefono con bandera AR +54

Los campos de telefono ya no piden escribir el codigo de pais: bandera argentina por defecto, cambiabile, y el numero se arma solo.

Robustez del frontend

El avatar ya no rompe con nombres vacios (antes deslogueaba). El arranque tolera tokens vencidos o la API caida sin dejar la pantalla en blanco. Candado anti doble-tap en login, registro y alta. Indicador 'escribiendo' en el chat.

Revision de cajas de texto

Se verificaron los 57 campos del formulario: todos con estilo correcto, ninguno como caja cruda del navegador.

4. Modulo de administrador (inteligencia de negocio)

Un panel privado, visible solo para el dueño (validado por email), que responde: cuanto cuesta y cuanto deja cada cliente, y como mejorar la rentabilidad.

Que incluye

- Instrumentacion de uso (tabla EventoUso, append-only): se registra cada accion que cuesta plata (chat, llamada, login) con su costo estimado.
- KPIs del negocio: ingreso mensual, costo del periodo, margen y clientes activos/total.
- Rentabilidad por cliente: ingreso vs costo, margen, mix de modulos, ultima actividad; ordenado por lo que da perdida primero.
- Asesor de rentabilidad: recomendaciones concretas (clientes en perdida, planes a mover, inactivos, trials por convertir) que funcionan sin IA, mas una narrativa opcional con IA.
- Pantalla en la app: KPIs, asesor y tabla de clientes, accesible desde 'Cuenta' solo si el backend reconoce al usuario como dueño.

Gating de negocio por plan

Las llamadas telefonicas (las mas caras) ahora exigen el plan Telefono: un cliente que pago el plan App ya no puede disparar el costo del plan caro. Las cuentas de obra social operan siempre (las cubre el prestador) y la prueba gratis puede usar todo.

5. Documentacion estrategica

Arquitectura para escalar a 1.000 - 10.000 clientes

Documento que define como guardar la informacion para crecer sin reescribir: separar datos vivos de historicos, migraciones versionadas (Alembic), Postgres real con pool, indices, archivado hot/cold del historial y transcripciones a object storage, cifrado por sobre (envelope encryption con KMS), y - lo mas urgente - instrumentar el uso desde hoy (ya hecho) para no perder datos despues.

Estrategia de marketing

Como presentar el producto a clientes: propuesta de valor ('tu viejo acompañado todos los dias, vos tranquilo'), segmentos (hijos que cuidan a distancia, adultos mayores, obras sociales B2B), posicionamiento frente a las alternativas, pricing y empaquetado, copy listo para landing y anuncios, manejo de objeciones, canales de adquisicion, embudo con KPIs ligados al panel BI, guion de venta y un plan de lanzamiento a 90 dias.

6. Historial de versiones de esta sesion

- 0.4.9** Arreglo del bug de llamada (numero plano + from de voz), campo Hora, carrusel mobile
- 0.4.10** Chat real del paciente con OpenAI
- 0.4.11** Badge de estado junto al nombre
- 0.4.12** Graficos de tendencia (sparklines)
- 0.4.13** Instrumentacion de uso (EventoUso)
- 0.4.14** Panel BI: endpoints de rentabilidad
- 0.4.15** [sec] Firma Twilio en /whatsapp/incoming + revision de cajas de texto
- 0.4.16** [sec] El chat valida la suscripcion de la familia
- 0.4.17** [sec] Secretos fail-closed en produccion
- 0.4.18** [sec] Rate limiting + endurecer login del paciente
- 0.4.19** Robustez del frontend (avatar, bootstrap, doble-submit, typing)
- 0.4.20** Gate de llamadas por plan + obra social siempre activa + indice
- 0.4.21** Asesor agentico de rentabilidad (/bi/asesor)
- 0.4.22** Panel del dueño (BI) en el frontend

Que sigue (del backlog priorizado)

- Adoptar Alembic (prerequisito para aplicar cambios de esquema en prod).
- Webhook de MercadoPago: que el pago active la suscripcion solo.
- Estados de offline / reintentar e iconos PNG de la PWA.
- Sacar el scheduler del proceso web y archivar el historial a object storage.

Todo el codigo esta en la rama claudie/charming-knuth-ud3pq5 y en main (Render despliega solo). 206 tests automatizados en verde.